Once Upon a Console: vCenter Console Coercion

trimarcsecurity.com/hub-post/once-upon-a-console

Brandon Colley November 16, 2023

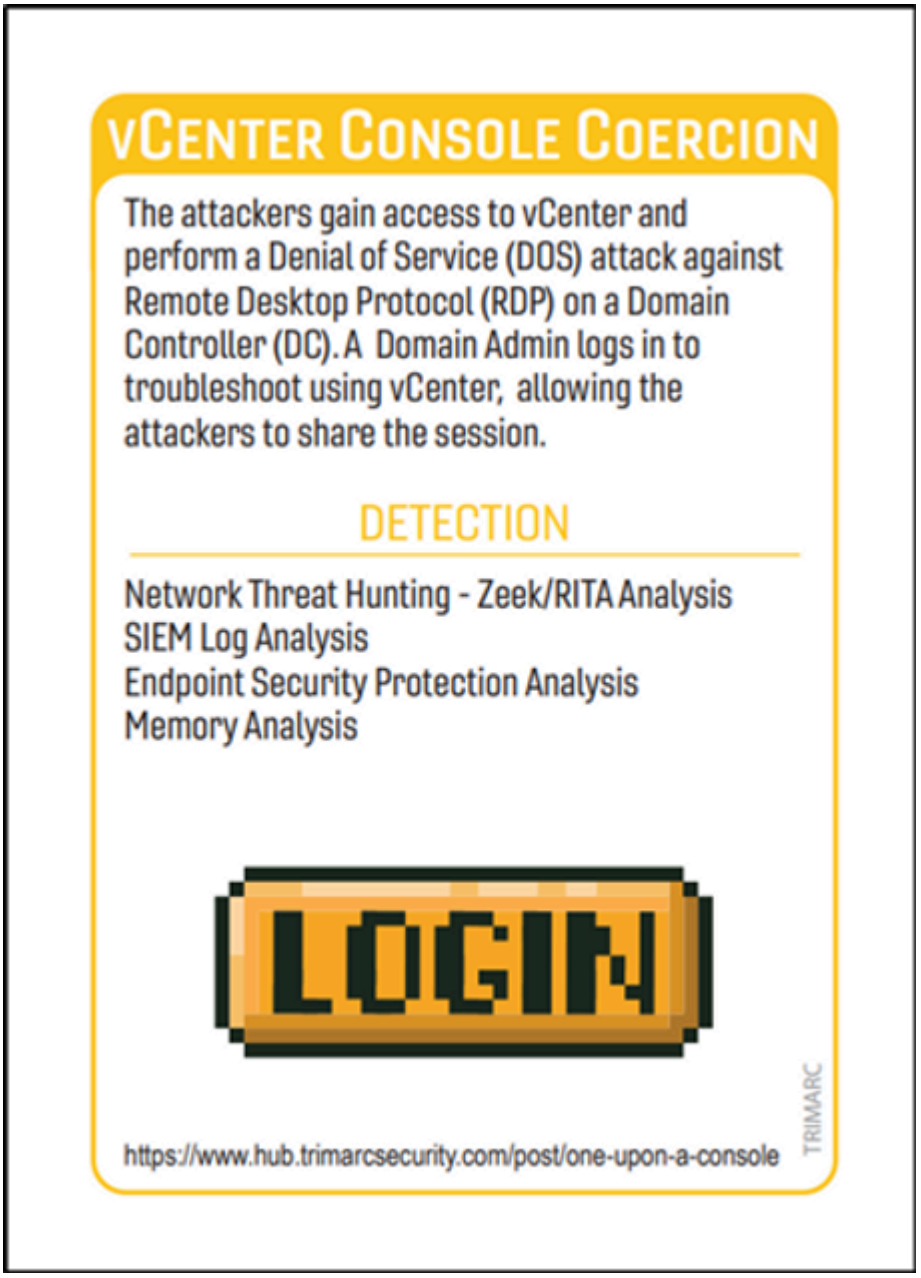
Updated: Dec 13, 2024

Prelude

Recent incident response reports tracking the steps of real attacker's sound like something out of a fairytale. Attackers have become craftier, more patient, and more creative. As a defender, I believe the best way to combat creative attackers is to become more creative ourselves. Looking beyond what attackers have historically done puts the defender into a mindset limited only by their own imagination.

Before we begin, I'd like to thank the folks at Black Hills Information Security (BHIS). As you may be aware, this article is a companion to the Trimarc expansion pack for Backdoors & Breaches. Jason and Deb, the curators of this wildly popular table-top game, are an inspiration. It has been a pleasure working with them on this project. They are creative defenders whose imaginations broaden the security landscape.

It is my greatest pleasure to present to you, the reader, Once Upon a Console.



Chapter 1 – Initial Compromise

The following events are not based on a true story and are entirely the manifestation from the loosely connected synapses of Brandon Colley. No hackers were harmed in the making of this story.

The morning of January 12 was like any other. Steve blinked open his eyes and checked his clock on the bedside table. 11:37am. “See, it’s still morning” he said to himself. Steve had spent the better part of the prior evening performing reconnaissance on his next target. Bison Sky Technologies (BS Tech) was an up-and-coming tech company, focusing on next generation of biometric authentication. They posted huge profits in Q4 last year and reportedly had begun beta testing products with several companies in the Fortune 500.

During the evening's planning session, Steve mapped out a strategy to pull off a cyber-attack against BS Tech. He scraped a list of over one-hundred employee names from social media and identified several products that made up their critical infrastructure that were included in recent BS Tech job postings. A simple scan of BisonSky.com revealed 3 pages where authentication was possible.

Feeling good about his upcoming attack, Steve dragged himself out of bed, grabbed a room temperature piece of pizza from an open box, and walked over to his computer. His desk had a glimmer of organization to it but held a few bits of clutter strewn around the monitors, keyboards, and notepads. A half-empty soda bottle sat next to a paper coaster from a nearby coffee shop. Useless swag from last year's DEFCON lay in a box tucked beneath the desk.

Steve opened a laptop while he shoved the last bite of pizza into his mouth. The laptop booted quickly, and his fingers danced across the keyboard with a familiar rhythm.

As the logon box faded, a background with a dragon logo briefly appeared before it was replaced by terminal windows splitting the monitor into four equal parts. In one terminal, Steve displayed the contents of the document containing a list of employee names. In the second terminal, he typed a short string of characters. He then hit the up arrow, made a few changes, and hit enter again. This pattern continued twice more. Steve opened a new file he had just created and gazed upon a list containing thousands of likely usernames.



Figure 1 Most of these images are generated with AI – Why a Racoon?

Next Steve opened a browser and a simple looking program that was divided into a few sub sections of different sizes. Using the browser, he typed in the first of the 3 discovered login pages he planned to attack. *BisonSky.com/portal* displayed a logon prompt. Steve clicked a few buttons on the program he previously opened then typed “test” into the browser’s username and password fields. Returning to the program, he clicked a few more times before resting his hands behind his head and leaning backwards.

Steve had just kicked off a password spray attack using the username list he created. Combined with a common password list, his program could attempt several logins each second. Within the next hour, Steve hoped to find a successful login credential.

That stretching of his arms and opening of his armpits stimulated Steve’s nostrils - and not in a good way. With eyes wide, the corners of his mouth turned downward. “This is a good

time to shower” he said walking away from his computer, toward the bathroom.

A few minutes later, Steve emerged pulling a black hoodie over his head. Before he even reached his desk chair, he could see his labor had born fruit. “Gotcha!” he smirked, spinning the chair around, ready to meet his victim.

Username: Zachary.Chester

Password: Winter2024!123

“Zachary, you devil,” he thought. “You really believed those extra 3 characters really mattered, huh?”

Steve refreshed his browser and confirmed the credentials worked by logging into the portal the old-fashioned way. Unfortunately, the portal didn’t contain anything interesting. It appeared this was simply a place for employees to set their personal details such as address, phone number, T-shirt size, etc. “It couldn’t have been THAT easy,” Steve thought. He did have valid credentials so maybe one of the other two webpages would prove more successful.

Looking down at his notepad, Steve looked at the URLs he’d jotted down last night. *BisonSky.com/webmail* and *BisonSky.com/VPN*. He could probably sift through Zachary’s emails and get something out of it, but the VPN (Virtual Private Network) could prove to be infinitely more profitable. Steve logged into the VPN portal but was quickly met with a roadblock. BS Tech had implemented multi-factor authentication (MFA).



Figure 2 Multifactor Authentication is almost spelled right

Steve was briefly stunned before he thought back to the portal he'd just logged into. He noted the last 4 digits of the phone number shown in the MFA prompt and logged back into the employee portal. "If these phone numbers match," he said, "I may be onto something."

Sure enough, the numbers matched.

Steve grabbed one of his burner phones, made sure it still had service, and changed Zachary's phone number in the employee portal to that of his burner. He logged into the VPN and was again met with the MFA prompt. A grinch smile spread across his face as he realized the last 4 digits of the phone number had changed.

Chapter 2 – Pivot and Escalate

Now that Steve was logged in through the VPN, it was as if he was sitting in a cubicle at BS Tech plugged directly into the corporate network. “I bet the dress code would have required me to wear slacks and a polo”, he laughed to himself. Steve opened his terminal windows again and typed a few commands into one before moving onto the second and third.

He kicked off a few scans to help map out what systems and services were available on the network and fired up a tool that listened to network traffic. Before long the terminals began scrolling at alarming rates. Steve’s eyes darted around the screen waiting for something to catch his attention. To an outside observer, he would’ve appeared entranced by the white text on a black background. There was a bit of a hypnotic pulse to how the lines of text climbed and fell.



Figure 3 He's gonna need those extra fingers to use a keyboard without a spacebar

This was far from Steve's first cyber-attack. Just before his 16th birthday, he had dabbled in illegal online activity. It started with pirating the newest movies and video games which turned into a short stint buying and selling illegal items on the dark web. Steve wasn't interested so much in the contraband; he just enjoyed the community and spent most nights chatting with new friends. It was in these chat rooms where Steve learned about attack tools and techniques. At first, he would try them out on his school network and local businesses, but eventually he started looking for targets that could make him a few bucks. The illegal marketplaces sold drugs, weapons, and movies but what always seemed to be most interesting to Steve was the data.

Unexpectedly, the wall of text stopped moving, waking Steve from his trance. He blinked quickly before focusing back on the terminal. Scrolling through the output, Steve noted anything of possible interest. He stopped and looked carefully at one line of text in particular. It was the IP address of a Domain Controller (DC). He clicked on another terminal window and typed in a tool name followed by the username and password he had obtained from Zachary. The connection was successful.

Steve had successfully authenticated to Active Directory (AD) and could now search for his next target. Zachary, as Steve might have guessed, didn't have any special privileges in AD, but this was no problem. Zachary had served his purpose. Steve began digging into AD by running a series of commands that helped identify possible targets.

His head cocked sideways, and his eyes tightened. He'd found an account named "helpdesk-dude". More importantly, the Description field was populated with "letmein". Steve also noted that this account was a member of several AD groups including one named "vCenter-ReadOnly". He continued through the list of accounts, jotting down a few more possible leads. Hitting the up arrow, Steve reconnected to AD but this time he wanted to test the helpdesk-dude account. Almost hoping it wouldn't work, Steve typed "letmein" for the password and chuckled when it connected successfully.

Chapter 3 – It's a Trap!

Returning to his scan output, Steve now had a new goal. He needed to search for anything to do with vCenter. Thinking back to his reconnaissance, Steve remembered that a job description mentioned "experience with VMware". From his previous experience he knew VMware was the company that owned the vCenter product. He thought that if this helpdesk account truly had access to vCenter it would be another opportunity to escalate privileges or get his hands on some juicy data.

Steve searched through his scan output for keywords but they kept returning zero results. Most of his output was just IPs and port numbers. He needed help translating this data into a network fingerprint that would be indicative of a system running vCenter. A quick internet

search gave him the information he needed. He modified his search criteria to include the list of ports commonly associated with vCenter and eureka, a hit. Steve excitedly typed the IP address into his web browser and was met with a familiar logon screen.

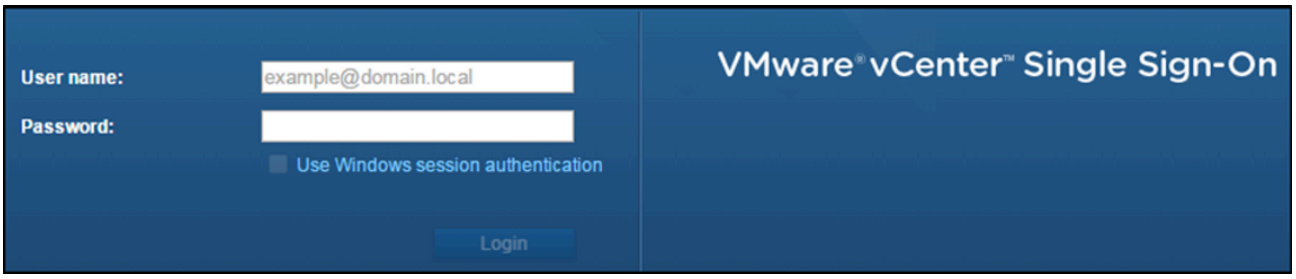


Figure 4 Not AI - Just logging into vCenter

He entered helpdesk-dude's credentials into the login form, clicked Login, and was sent to the vCenter home screen. Steve had a full inventory of 307 servers before him. He pushed himself away from his desk, planning his next move. Crossing his arms, he thought through his options. He could create havoc by randomly shutting down servers. That might be fun, he thought, but it wasn't his primary objective. He could download all the virtual hard drives.

"Wow, 300 multiplied by what?", he thought, "maybe an average of 80GB. That's something like 24TB of data." He looked down at the desktop computer sitting on the floor. Before even trying to calculate the storage or the amount of time it might take to download, he needed to see if it was even a possibility.

Steve clicked through the side menu, selected a server at random and right clicked on it. Most of the options were grayed out. "Read Only" he pondered while shaking his head. He couldn't access the hard drives. Heck, he couldn't even shutdown the systems. Maybe he could at least export a list of servers. That might be helpful later. As his cursor began to drop through the server menu options, the console link lit up. Steve hesitated a moment before clicking.



Figure 5 It's 8:22 somewhere!

“If anyone left an open session on one of these servers, I’d really be able to do some damage” he thought. Steve began clicking through consoles energetically. After viewing about 3 dozen servers, his pointer finger was sore, and his head was starting to hurt. Watching window after window expand brightly but without victory was getting on his nerves. Steve had been so spoiled getting this far, he had hoped for some more good fortune. He stood up from his desk and stretched his fingers backwards in an effort to relieve the ache. Steve reached back into the pizza box, pulled out the last piece and thought while he ate.

“Why do administrators log into a console?” he said to himself. Pondering this question, Steve thought about deploying some social engineering techniques to convince an admin to log onto a console, but he’d never been very good at pretending to be someone else. But that thought got his creative thoughts flowing. “I don’t need to verbally convince someone to login,” he thought while sitting back down. Steve began typing on his console again. Glancing back at his notes, he prepared a few scripts to target the IP address of the DC he had found earlier.

The scripts he was writing were intended to perform a Denial-of-Service (DoS) attack. Steve was specifically trying to hinder the Internet Control Message Protocol (ICMP) response time. This attack is also referred to as a ping flood. He hoped this would trigger an alarm and get the attention of an unsuspecting administrator. The second phase of his attack was to similarly impact port 3389. This port is used for Remote Desktop Protocol (RDP). Steve expected the administrator to first attempt a remote desktop session, but because Steve had DoSed the RDP service, this RDP session would fail. The resultant

scenario would coerce the administrator to login to vCenter to view the DC through the Virtual Console.

With his plan in motion, Steve stared excitedly at the logon screen and prayed for it to change.

Chapter 4 – Bill

“INC#104822 resolved” displayed across a banner atop a browser window. A table expanded across the screen listing row after row of open incident requests. “Page 1 of 3” displayed in the lower right-hand corner. Bill took a deep breath and glanced at the clock. It was already past 4pm and he hadn’t even had lunch yet. Bill didn’t have time to take a break. He had an important appointment at 5 and was already buried in work. He opened another can of green soda and clicked on the next incident in his list, Bill read out loud.

10:10am

I need to get access to the Marketing services file share. Nancy said I needed to send an email.

11:57am

I just tried again, and it says access denied. Did you already do something? I really need this before the end of the day.

1:20pm

I got back from lunch, and it still isn’t working. My printer also stopped printing. Could that be related?

Glancing over at his email, he saw that he’d also gotten a direct email from Nancy James-Donahue, his boss was copied on it. Bill clicked on the trash logo next to it and began replying to the incident request. To no one in particular, Bill spoke while he typed: “Timothy, Thank you for your patience. Could you please provide the full file path for the Marketing share? There are 4 different Marketing shares. - Bill”. Clicking on submit, another email popped into his inbox. It was the automated system that so conveniently sent emails for all communications within the ticketing system. A second email appeared; the subject line read: “Consecutive ICMP failure - BSCTDC012 down!”

“Oh great.” said Bill, slouching further into his chair. Almost ceremoniously, he pointed at his phone, “buzz” he said as the phone vibrated and lit up with a text alarm. His inbox was quickly flooded with a dozen more of the same failure messages. Obviously annoyed, he opened a command prompt and attempted a ping of his own. He was fairly conditioned to expect false alarms, but to his disappointment, his ping also failed. Bill clicked on the Start Menu and brought up the Remote Desktop Connection application. He typed in the server

name and clicked Connect. A loading bar appeared with the text “Initiating remote connection…” beneath it. After 30 seconds, an error message appeared. He checked that he hadn’t misspelled the server's name and tried a second time. It ended in the same result.

Bill glanced at the clock again, suddenly realizing the predicament he was in. His boss was out on vacation this week, and his other two co-workers clock out at 3:30 sharp. The only warm body in the office besides Bill was a junior administrator that had been hired less than a month ago.

Luckily for Bill, whatever outage was occurring seemed isolated to one server. He logged into the vCenter web interface, typed BSCTDC012 and saw the server seemed to be powered on. He clicked on the console menu and was met with the typical logon prompt. Bill typed in his Domain Admin credentials and pressed Enter. It was only then that he noticed a yellow warning atop the console window.

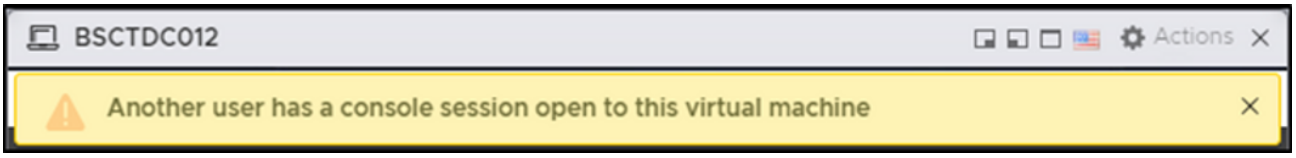


Figure 6 Another user has a console session open to this virtual machine

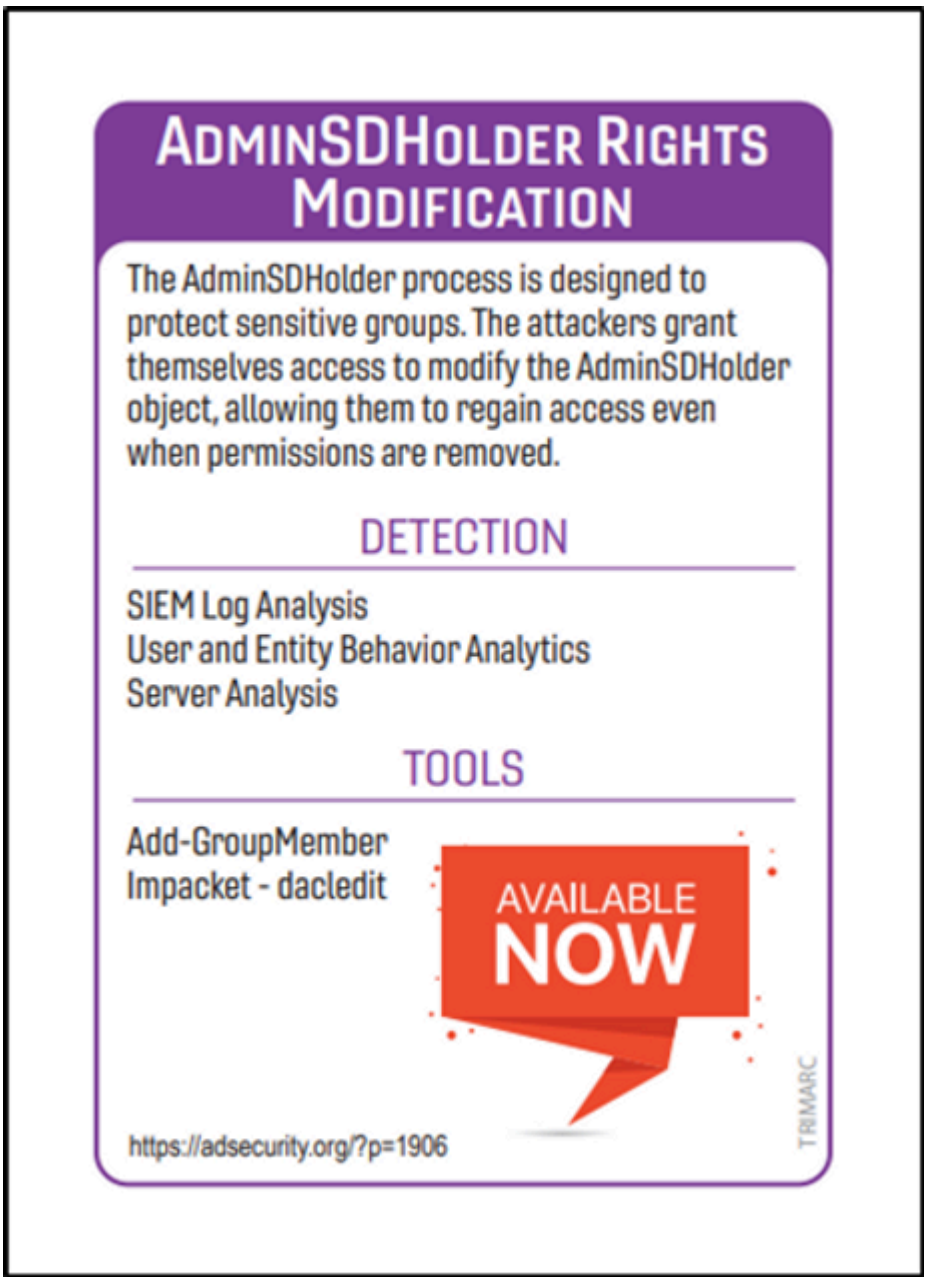
Bill dismissed the warning without a second thought. He’d seen it before. Maybe someone else left a browser window open? Or maybe he accidentally clicked the console button twice in his haste? Either way, he was on a mission to solve an outage, and he needed it done quickly. As the DC’s desktop loaded, he noted it was already 4:43pm. “I should have left 5 minutes ago” he thought to himself, opening a command prompt.

Bill furiously typed in a few commands, confirming the networking looked correct. He tested connectivity from the DC to other devices on the network. Everything looked fine. He clicked back to his computer and performed the same ping check he had previously. The server responded this time. He saw he’d received an email: “Connectivity restored - BSCTDC012”. Bill grabbed his phone, threw on his coat, locked his workstation, and ran out the door.

Chapter 5 – Domain Admin

Steve sat motionless for a good two minutes. Had his plan worked? He watched as Bill had logged in and ran commands. The cursor was still blinking, seemingly left behind. Steve carefully wiggled the mouse - he didn’t want to be detected but also couldn’t afford to allow the lock screen to engage. He needed to tread carefully as he only had a very fragile foothold. Creating persistence was his next goal.

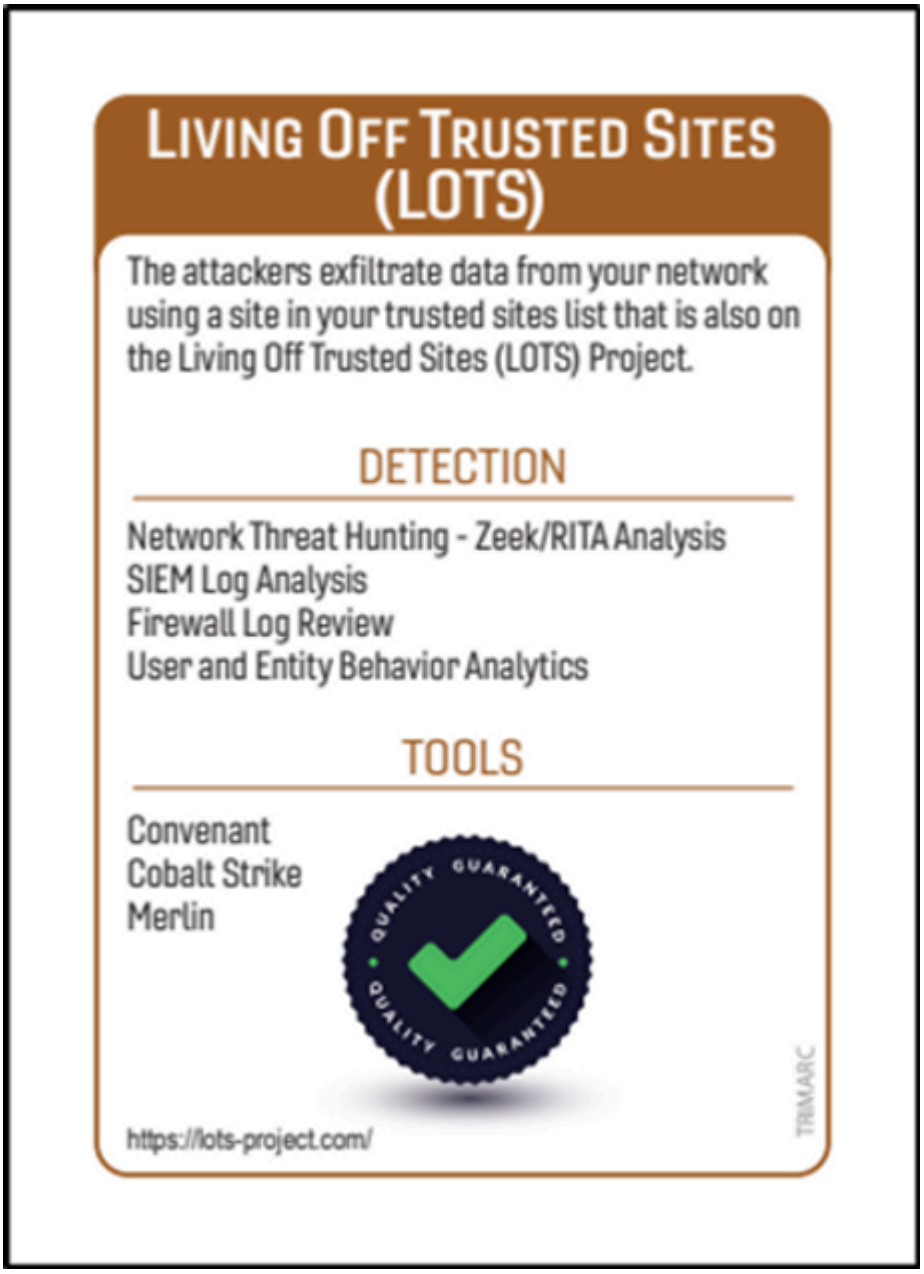
Steve pulled up his notebook with a list of commands he could run to create persistence in an AD environment. He first created a new account, taking time to ensure it looked like other accounts in the environment. Adding the account directly to the Domain Admins group was too obvious. He decided to go after the AdminSDHolder process. Steve modified the AdminSDHolder object with appropriate permissions to grant his backdoor account the ability to regain AD rights whenever he needed.



His next step was to exfiltrate data. Steve didn't know if he'd ever have the opportunity to access a DC again, so he decided to take a copy with him. Running a simple command, he created a backup of AD. Now, he had to find a way to get it out of the BS Tech network. DCs are usually pretty limited to what they can access on the internet.

Steve opened a web browser to identify any websites that may be marked as trusted. Cross-checking this list against the LOTS project, he identified one that could be used for exfil. Simply logging in using one of his burner accounts, Steve uploaded the AD backup

files. Turning back to his laptop's browser, he logged into the very same website and downloaded the content he had just uploaded.



Steve had completed the initial phases of his plan. With the AD backup files, he could probably extract dozens, if not hundreds of credentials. He also had the blueprint for their environment. By studying it, he could identify other weak points to leverage in future attacks. Armed with this data - and his sneaky backdoor - Steve imagined he could persist in the BS Tech network for months.

Chapter 6 – Remediation

Pshhh

Bill cracked opened his third soda of the day. Some things never change, but fortunately for Bill several things were changing for the better. BS Tech had recovered from their breach and were taking strong measures to ensure it didn't happen again. It had been

several weeks since the incident, and the response team had wrapped up their work, feeling confident the attacker had been removed from the network. The upper administration at BS Tech were carefully reviewing the incident response report and had already initiated several remediation efforts.

Public access to the Human Resources portal was removed. Employee access to the portal was now available only when physically on site or connected through the VPN. The system now alerted employees via email whenever their profile was changed. While the VPN already required MFA, access was now restricted only to employees that needed it. The network team was also working to implement segmentation so employees could only access certain services when connected to the VPN.

A similar effort was underway to restrict access to crucial systems such as vCenter. Now, only administrative workstations could connect to highly privileged systems. A permissions audit task was given to Bill to complete. He already deleted the “helpdesk-dude” account, but permissions had sprawled out of control over the last several years. Bill was also taking a closer look at AD, making sure no passwords were in description fields. He began investigating change monitoring solutions to detect when sensitive changes were made to AD.

Stricter guidelines for accounts and passwords were also being turned into policies. Passwords now must go through a filter to prevent the use of common, weak, or breached passwords. Account lockout for failed logon attempts was tightened up, and password spray detections were being put into place.

Perhaps Bill’s favorite change of all was alert tuning. He very much looked forward to fewer emails and false alarms. A renewed focus on high fidelity alerting and detection techniques was really going to help level up security for BS Tech.

This whole ordeal really helped re-ignite Bill’s interest in information security. He was impressed at the ingenuity the attacker had showed to persuade when persuading him to log into vCenter so they could mirror his console session. Bill would never look at abnormalities the same way again. He was clever too, and he was convinced that he was just as intelligent as whoever this attacker was.

The next morning, Bill woke up and walked down the street to his favorite coffee shop. He was meeting an old friend from the local tech college they both attended. Bill entered, immediately recognizing his old friend. “Hey!” he shouted, “So good to see you”. The two hugged each other. Bill asked, “So, what have you been up to recently Steve?”